Meridian Studios LLC

Information Security Policy

Security Program · Risk Assessment · Incident Response Plan
Written 2026-09-19 · Exported for Plaid production review 2026-09-26

This document comprises the written security program, the risk assessment, and the incident response plan of Meridian Studios LLC (the "Company"), in that order. These are the three documents required by the GLBA Safeguards Rule and requested by Plaid's security questionnaire. The document is maintained in the product's version-controlled repository alongside the code it describes.

Every statement in this document is accurate as written, or names a planned change and its date. When the system changes, this document is updated in the same commit.

1. Security Program

1.1 Organization. Meridian is built and operated by one person, Gaetan Almela, under Meridian Studios LLC. The developer, the operator, and the security officer are the same person. This program is written for a company of that size.

1.2 Data held. The Company holds bank and brokerage balances, transactions, merchant names, email addresses, and Plaid access tokens, for US users only. All data resides in one Postgres database on one DigitalOcean droplet. Subprocessors are Plaid, Stripe, Resend, and DigitalOcean, named in the privacy policy at `meridiancash.io/privacy`.

1.3 Encryption in transit. TLS is used on every hop. The public surface terminates at Caddy with certificates it manages. The application reaches Postgres with `sslmode=verify-full` against a private certificate authority; a downgrade is refused rather than falling back. The web container briefly answered plain HTTP on a public port; this was found and closed 2026-09-23, and the port now binds to loopback only.

1.4 Encryption at rest. Plaid access tokens, the credential that reads a bank, are sealed at the application level with AES-256-GCM before they reach the database. The database resides on a DigitalOcean Block Storage Volume, LUKS-encrypted by DigitalOcean with a key DigitalOcean holds, since 2026-09-21. Droplet snapshots taken before that date hold the data in plain text until they age out, by 2026-10-19.

1.5 Access control. SSH access to the server is by key only, from one authorized machine. There is no admin panel and no support tooling, and production data is not read for debugging; this is standing policy. Linking a bank requires a paid subscription, and the number of bank connections held is capped, so exposure grows only with paying customers.

1.6 Multi-factor authentication. Every point of access was reviewed 2026-09-23. SSH to the server is key-only, with password and keyboard-interactive authentication disabled and root login disabled; Postgres listens on loopback only. Neither therefore has a password to place a second factor behind. Plaid, Stripe, GitHub, and Apple each have 2FA enabled. DigitalOcean is accessed through Google sign-in, so its second factor is that of the Google account, which has 2FA enabled; that Google account is treated as an access point of the same rank as the console it opens. The password manager holding every escrowed key is protected by its master password alone; this risk was considered and accepted 2026-09-23, and is revisited at each scheduled review of this program (section 1.12).

1.7 Secrets management. The server's secrets are held in an environment file on the server, readable only there. The token-sealing key, the backup encryption key, the Plaid secret, and the Postgres password are escrowed in a password manager (completed 2026-09-23). The sealing key is escrowed apart from the data it protects, and the Volume and the backups are encrypted under distinct keys, so no single key exposes more

than one layer. Each sealed record carries a version byte, so keys can be rotated — and key storage migrated — without loss of access to existing records.

1.8 Logging. Every call crossing the network is logged, both request and response, with credentials stripped: a secret or access token is logged as its length, never its value. Log lines carry the commit that produced them.

1.9 Audit log. Separate from the application logs, an append-only audit table records every response that serves customer data — whose data, what data, from what address, and when — and every backup, which reads all of it. The table refuses `UPDATE` and `DELETE` statements, rows survive account deletion, and the nightly dump carries the log off the server, so tampering with the on-server copy is detectable. Direct database access is not audited; the compensating controls are that production reads do not occur, and the access controls in section 1.5.

1.10 Account deletion. A user can delete their account end to end — the ledger, the Plaid connections, and the Stripe customer — behind a confirmation and an emailed six-digit code. Deletion is verified by automated server-side tests.

1.11 Backups. A daily `pg_dump` is encrypted on the server with a public key the server cannot decrypt with, and uploaded to object storage with 30-day retention. The restore has been run end to end from that storage using only what the password manager holds. Weekly droplet snapshots and a manual offline dump are the second and third copies. The backup bucket shares the DigitalOcean account with the server; this risk was accepted 2026-09-21 and is revisited as the user base grows.

1.12 Review. This program is reviewed at every Plaid milestone — the questionnaire, the production application, the first real customer — and at least yearly. Each review is dated at the top of the document.

2. Risk Assessment

The risks below are ordered by severity. Each names its control or its accepted gap; an accepted risk carries the date it was accepted.

1. **Server compromise.** This is the worst case: a root compromise of the server could read the sealed tokens and the key that opens them. The risk is contained by the small surface (one binary, Caddy, and Postgres, nothing else), key-only SSH from one machine, and the cap on connections held, and is answered after the fact by the incident response plan below.
2. **Leak of a disk copy** — a snapshot, a decommissioned drive, or a backup outside its intended location. The database is on an encrypted Volume and every dump in the bucket is encrypted, so this risk reduces to a leak of key material, which the password manager holds. The exception is the pre-migration droplet snapshots, which hold plaintext until 2026-10-19.
3. **Takeover of a console account.** DigitalOcean holds the server and its backups in one account; Plaid and Stripe hold the data and the money. The control is MFA on every account, verified 2026-09-23.
4. **Loss of the server** — deleted, corrupted, or region outage. The risk is availability alone, not data exposure: every secret a rebuild needs is in the password manager, and the controls are the off-site dumps and a restore that has been run in practice.
5. **Misuse of data rather than theft.** The standing rules are: no selling or sharing of data, no transactions sent to third-party LLMs without zero retention, no tokens in logs, no data kept after deletion, and no scopes beyond what is used. A one-person company has no insider to guard against, but also no second reviewer; the compensating controls are that every served read and every backup lands in the append-only audit log, and that production data is not read directly at all.

3. Incident Response Plan

The Company is one person, so the plan is a sequential checklist rather than an escalation chart. The steps are executed in order.

1. **Contain.** A single deploy command stops the server and closes the public surface. A deploy does not require the server to be trusted: images rebuild from source control on a separate machine.

2. **Revoke bank access.** Rotate the Plaid secret in the dashboard. If tokens may have leaked, remove every bank connection at Plaid, which invalidates the tokens regardless of who holds them. Users relink their banks; this cost is accepted.
3. **Rotate remaining credentials.** Rotate the Postgres password, the token-sealing key (a reseal, possible while the old key is still held), the SSH keys, and any console password involved.
4. **Establish scope from the logs.** Every network call is logged with its commit. What was read, by whom, and since when is determined from the application logs and the audit log, not from recollection.
5. **Notify.** Notify Plaid promptly, per its contract. Notify users whose data was exposed, plainly and quickly. Notify the FTC within 30 days if 500 or more users are affected (Safeguards Rule), and comply with the breach-notification law of each affected user's state. With under 500 users total today, the practical duty is notification of Plaid and of the users themselves.
6. **Recover.** Redeploy from source control, restore the database from the most recent dump, and verify with the deployment's health check.
7. **Document.** Record what happened, when it was noticed, what was done, and what changes — appended to this document.